

PORTFOLIO | GOVERNANCE, RISK & COMPLIANCE CASE STUDY

ISO/IEC 27001:2022 Readiness Assessment

Data Centre & Network Infrastructure Scope

An end-to-end information security management system (ISMS) gap assessment carried out for a regulated financial services organisation in Southeast Asia: scope definition, risk assessment, Statement of Applicability, gap analysis across all 22 management-system requirements and 93 Annex A controls, a costed corrective action plan, and a six-month roadmap to certification readiness.

Prepared by	Papras Nualchaem — MSc Cyber Security candidate
Standard	ISO/IEC 27001:2022 (with ISO/IEC 27002:2022 control guidance)
Client	Anonymised — a regulated financial services organisation in Southeast Asia
Engagement type	Pre-certification readiness assessment (academic case study, non-certifying)
Role	Assessment team member (eight-person postgraduate team)
Document date	September 2026

Confidentiality statement

All identifying information has been removed from this portfolio version. The client organisation, its personnel, vendors, network diagrams, IP addressing, firewall rules, system configurations and user identities are not disclosed. Figures are presented at an aggregate level only.

This assessment was performed for educational purposes. It is not a certification audit and does not constitute an accredited third-party opinion.

1. Project Snapshot

Business context	A regulated financial services organisation whose customer service, transaction processing and data retention depend entirely on its own data centre and network infrastructure. Availability and integrity of that infrastructure are the operational backbone of the business.
Problem	The organisation intended to pursue ISO/IEC 27001:2022 certification but had no objective view of how far its existing controls, documentation and evidence would satisfy an auditor.
Assessed scope	Data Centre Service · Network Security · Support Facility & Infrastructure · Access Management · Incident and Continuity Management
Methods	Documentation review · structured control questionnaire · stakeholder interviews (IT/Infra, Network, DC Operations, Facility, Management) · physical site survey
Assessed items	115 in total — 22 management-system requirements (Clauses 4–10) and 93 Annex A controls
Headline result	Practical readiness 86.09% · 89 controls implemented (77.39%) · 15 gaps identified and scheduled for closure
Deliverables	ISMS scope statement · risk assessment methodology · risk register · draft Statement of Applicability · gap register · corrective action plan (10 actions) · required evidence list · executive dashboard · six-month roadmap

Result at a glance

Assessment status	Clauses 4–10	Annex A	Total	Share
Implemented	18	71	89	77.39%
Partially implemented	3	7	10	8.70%
Not implemented	1	4	5	4.35%
Out of scope	0	11	11	9.57%
Total assessed	22	93	115	100.00%

Practical readiness — implemented plus partially implemented items, excluding out-of-scope controls from the numerator — was **86.09%**. The organisation had strong operational and physical controls but an incomplete management-system layer: the plan-do-check-act loop was not yet closing.

2. ISMS Scope and Organisational Context

Clause 4 of the standard requires an organisation to understand its context, identify interested parties and their requirements, and document the boundaries of the ISMS. Scope definition is the single most consequential decision in a certification project: it determines which controls are auditable and it is the first document a Stage 1 auditor reads. The statement below was drafted for the client and forms the reference point for every finding in this report.

2.1 ISMS scope statement

Scope statement (drafted)

The information security management system covers the protection of the confidentiality, integrity and availability of information and information-processing facilities within the organisation's primary data centre and corporate network infrastructure. This includes the physical data centre environment and its supporting facilities, network and connectivity services, privileged and physical access management for those environments, and the incident response and service continuity processes that protect them, as operated by the IT Infrastructure, Network and Facility functions.

2.2 Scope boundaries

Scope area	What was assessed	Representative Annex A controls
Data Centre Service	Physical and environmental security of the data hall, access logging, CCTV and monitoring	A.7.1–A.7.4, A.7.6, A.8.16

Scope area	What was assessed	Representative Annex A controls
Network Security	Network security management, segregation, connection control and logging	A.8.20–A.8.23, A.8.15
Support Facility & Infrastructure	UPS, generator, cooling, fire suppression, preventive maintenance	A.7.5, A.7.8, A.7.11–A.7.13
Access Management	Physical and logical access rights, privileged access, visitor handling, periodic review	A.5.15–A.5.18, A.8.2, A.8.5
Incident & Continuity Management	Incident response and escalation, backup and restore, continuity of infrastructure services	A.5.24–A.5.28, A.5.29–A.5.30, A.8.13

2.3 Documented exclusions

Exclusions were recorded with justification so that an auditor can trace why an area sits outside the certified boundary. Anything excluded here must still be covered by an interface agreement with the owning function.

- End-user devices and endpoint management — owned by IT Service Desk; interface: endpoint incidents feed the same incident process.
- External networks beyond the organisation's administrative control — covered by supplier and connectivity agreements.
- Application-level processing of personal data, transaction data and business-confidential records — owned by Data Governance and application teams.
- Business process controls such as approval hierarchies and segregation of duties in operational workflows — owned by Business Operations and Internal Audit.

2.4 Interested parties and their requirements

Interested party	Requirement	ISMS implication
Financial regulator and supervisory bodies	Demonstrable IT risk management, incident reporting and business continuity for a regulated financial institution	Clause 6.1 risk process, A.5.24–A.5.30, evidence retention
Customers	Uninterrupted service availability and protection of their data	Availability objectives, A.8.13 backup, A.5.29 continuity
Executive management and board	Assurance that IT risk is measured, reported and within appetite	Clause 9.3 management review, security KPIs
Suppliers and outsourced technicians	Clear rules for working in secure areas and on infrastructure	A.5.19–A.5.22, A.7.6
Internal audit and compliance	Auditable records of control operation	Clause 7.5 documented information, Clause 9.2
IT, Network and Facility staff	Workable procedures and defined responsibilities	A.5.2 roles, Clause 7.2 competence

2.5 Why confidentiality, integrity and availability matter in this scope

Confidentiality	Prevents unauthorised physical or logical access to the data hall, network devices and the information they carry. A breach here bypasses every application-layer control above it.
Integrity	Protects the correctness of device configurations, change records and log data. Without integrity, incident investigation and audit evidence become unreliable.
Availability	The dominant driver in this environment: power, cooling, network and backup failures translate directly into service outages, customer impact and regulatory attention.

3. Assessment and Risk Methodology

3.1 How the assessment was run

Method	Purpose	What it produced
Document review	Test whether required documented information exists, is approved and is current	Document master list, Clause 7.5 gaps
Control questionnaire	Rate each of the 115 items against a defined maturity scale	Raw assessment dataset feeding the dashboard
Stakeholder interviews	Confirm what is actually done, not only what is written	Practice-versus-policy differences, e.g. A.5.13 and A.5.14
Site survey	Observe physical and environmental controls first-hand within permitted limits	Secure-area evidence gaps, signage and visitor-control findings

3.2 Readiness rating scale

Rating	Definition	Auditor view
Implemented	Documented process, assigned owner, operating consistently, and verifiable records exist	Conformity
Partial	Control operates but documentation, evidence or consistency is incomplete	Likely minor nonconformity or observation
Not implemented	No process or no evidence within the assessed scope	Major or minor nonconformity depending on the requirement
Out of scope	Not applicable to this boundary or owned by another function; requires SoA justification	Accepted only with a documented rationale

3.3 Risk assessment and treatment methodology

Clause 6.1.2 requires a defined, repeatable and comparable risk process; Clause 6.1.3 requires that treatment choices are traceable to Annex A. The original engagement produced a qualitative risk list, so a scored 5x5 methodology was defined and applied so that remediation could be prioritised on evidence rather than intuition.

Score	Likelihood	Impact on the assessed scope
1	Rare — no occurrence expected in 3 years	Negligible — no service or compliance effect
2	Unlikely — could occur once in 2–3 years	Minor — internal effect, absorbed by existing capacity
3	Possible — could occur annually	Moderate — degraded service or an audit observation
4	Likely — expected within 12 months	Major — service outage, customer impact or nonconformity
5	Almost certain — already occurring or imminent	Severe — prolonged outage, regulatory or reputational damage

Risk level	Score (L × I)	Decision rule	Response time
Critical	15 – 25	Not acceptable — immediate treatment, executive visibility	Plan within 2 weeks
High	10 – 14	Not acceptable — treat within the current cycle	Plan within 1 month
Medium	5 – 9	Treat where cost-effective; otherwise accept with sign-off	Plan within 1 quarter
Low	1 – 4	Within appetite — monitor only	Review annually

Risk appetite: residual risk of 6 or below is acceptable for infrastructure risks; anything above requires a treatment plan with a named owner and a due date. Treatment options are modify (apply or strengthen an Annex A control), avoid, share (transfer to a supplier or insurer) or retain with documented acceptance.

4. Assessment Results

4.1 Management system requirements (Clauses 4–10)

Eighteen of the 22 requirements were satisfied. The four exceptions all sit in the "check and act" half of the management cycle — the organisation was operating security well but was not yet measuring, reviewing and improving it in a way an auditor could evidence.

Clause	Requirement	Status	Finding
6.2	Information security objectives	Partial	Uptime targets existed, but no security-specific KPIs with owners, targets and reporting frequency.
7.1	Resources	Partial	ISMS resourcing was assumed rather than planned; no allocation for gap closure or audit preparation.
7.4	Communication	Partial	No defined plan for what is communicated about the ISMS, to whom, when and by whom.
9.1	Monitoring, measurement, analysis and evaluation	Partial	SOC reporting existed but was not linked to ISMS objectives through a checklist or metric set.
9.3	Management review	Not implemented	No management review had been held; inputs were awaiting the gap assessment and internal audit.
10.1	Continual improvement	Partial	Improvements were tracked in an IT ticket log, not in a formal corrective action register with root-cause analysis.

Clauses 4 (context), 5 (leadership and policy), 6.1 (risk), 7.2–7.3 (competence and awareness), 7.5 (documented information), 8 (operational planning, risk assessment and treatment) and 9.2 (internal audit programme) were assessed as implemented.

4.2 Annex A controls by theme

ISO/IEC 27001:2022 restructured Annex A from 114 controls in 14 clauses into 93 controls across four themes. Mapping the findings onto those themes showed that every gap was organisational or physical; the technological control set was clean.

Annex A theme	Controls	Gaps found	Nature of the gaps
A.5 Organisational	37	7	Threat intelligence, evidence collection, compliance verification, labelling, transfer, segregation of duties, security in project management
A.6 People	8	1	Remote working — scope rationale not documented
A.7 Physical	14	3	Working in secure areas; clear desk and clear screen and off-premises assets both need scope justification
A.8 Technological	34	0	No gaps identified within the assessed boundary
Total	93	11	7 partial + 4 not implemented; a further 11 controls were rated out of scope

4.3 Gap register

Control	Name	Status	Required action
A.5.3	Segregation of duties	Not impl.	Confirm as out of scope with a documented rationale, or transfer to Business Operations
A.5.7	Threat intelligence	Partial	Formalise collection, analysis and feed-through into control changes; retain records of use
A.5.8	Information security in project management	Not impl.	Refer to the PMO and record the interface in the SoA

Control	Name	Status	Required action
A.5.13	Labelling of information	Partial	Publish or reference an information labelling standard for in-scope records
A.5.14	Information transfer	Partial	Document how logs, reports and evidence move between functions
A.5.28	Collection of evidence	Partial	Write a digital evidence handling work instruction with a chain-of-custody template
A.5.36	Compliance with policies, rules and standards	Partial	Introduce a walkthrough checklist and a defined verification cycle with records
A.6.7	Remote working	Partial	Define remote access conditions for infrastructure support and justify the boundary
A.7.6	Working in secure areas	Partial	Add no-photography signage, visitor records and contractor rules for the data hall
A.7.7	Clear desk and clear screen	Not impl.	Reclassify as out of scope (general office environment) with rationale
A.7.9	Security of assets off-premises	Not impl.	Refer to Endpoint and Asset Management; record the rationale in the SoA

Interpretation note

Several "not implemented" ratings reflect boundary questions rather than absent controls. Where a control belongs to HR, the PMO, Data Governance or Endpoint Management, the finding is that the Statement of Applicability does not yet record why — an auditor will raise the missing justification, not the missing control. Treating these correctly avoids both an unnecessary remediation cost and an avoidable nonconformity.

5. Risk Register and Remediation Plan

5.1 Scored risk register

Each gap was expressed as a risk scenario, scored with the 5x5 methodology, assigned a treatment option and re-scored to show the residual position once the corrective action is complete.

ID	Risk scenario	L	I	Inherent	Treatment	Control ref.	Residual	Level
R01	Management review is not held, so ISMS performance never reaches executive decision-making	4	3	12 High	Modify	Cl. 9.3	6	Medium
R02	Absence of security KPIs leaves control effectiveness unmeasured and objectives unverifiable	4	3	12 High	Modify	Cl. 6.2, 9.1	6	Medium
R03	Improvements tracked only in tickets, so recurring infrastructure faults are never root-caused	3	3	9 Medium	Modify	Cl. 10.1, 10.2	4	Low
R04	Digital evidence is collected without integrity controls, weakening incident investigation	3	4	12 High	Modify	A.5.28	8	Medium
R05	Incomplete secure-area evidence allows unrecorded access to the data hall by third parties	3	4	12 High	Modify	A.7.6, A.7.2	8	Medium
R06	Unjustified SoA entries cause nonconformities at Stage 1 and stall the certification timeline	4	3	12 High	Modify	Cl. 6.1.3 d)	3	Low
R07	Threat intelligence is consumed informally and does not drive control changes	3	3	9 Medium	Modify	A.5.7	4	Low
R08	No labelling or transfer standard for in-scope records, risking mishandled evidence and reports	3	2	6 Medium	Modify	A.5.13, A.5.14	4	Low

5.2 Corrective action plan

ID	Corrective action	Owner	Evidence produced	Priority / effort
CA-01	Run a management review: agenda, minutes, decisions and action log	ISMS Manager	Agenda, minutes, decision log	P1 · Low effort
CA-02	Define security KPIs with targets, owners and reporting frequency	IT Security / Network Lead	KPI register, dashboard	P1 · Medium
CA-03	Build an ISMS monitoring checklist and periodic analysis report	IT Security / Network Lead	Monitoring checklist, monthly report	P1 · Medium
CA-04	Establish a central corrective action log with root cause, owner, due date and verification	ISMS Manager / IT Operations	Corrective action log	P1 · Low
CA-05	Write a digital evidence handling work instruction and chain-of-custody template	IT Security / Compliance	Work instruction, template	P2 · Medium
CA-06	Introduce an on-site compliance walkthrough checklist and verification cycle	Compliance / IT Security	Checklist, review records	P2 · Low
CA-07	Strengthen secure-area controls: signage, visitor records, contractor rules	DC Operations / Physical Security	Signage record, visitor and contractor logs	P2 · Low
CA-08	Review and justify every not-implemented and out-of-scope control in the SoA	ISMS Manager / Compliance	Updated SoA with rationale	P1 · Medium
CA-09	Produce an ISMS resource plan and RACI matrix	ISMS Manager / IT Security	Resource plan, RACI matrix	P3 · Low
CA-10	Publish an ISMS communication plan covering internal and external reporting	ISMS Manager / Compliance	Communication plan, records	P3 · Low

6. Closing the Management-System Loop

The four elements below were the substance of the remediation work: they are what turns a well-run infrastructure team into a certifiable management system. Each was drafted as a working artefact rather than a recommendation.

6.1 Statement of Applicability

The SoA is the controlling document of a certification audit: for all 93 Annex A controls it must state applicability, justification for inclusion or exclusion, implementation status and a reference to where the control is realised. The draft produced here records five fields per control.

Applicability	Applicable / partially applicable / not applicable to the defined boundary
Justification	Why — tied to risk assessment output, legal or regulatory requirement, or contractual obligation
Current status	Implemented / partial / not implemented, consistent with the gap register
Implementation ref.	The policy, procedure or record where the control is realised
Required action	Open item, owner and target date where the status is not "implemented"

The most common cause of a Stage 1 delay is an SoA that excludes controls without a defensible rationale. Eleven out-of-scope and four not-implemented controls were flagged for rationale review before submission.

6.2 Mandatory documented information

The standard names the records an auditor will always ask for. Mapping the client's documentation against this list turned "we have policies" into a defensible completeness check.

Clause	Required documented information	Status at assessment
4.3	Scope of the ISMS	Drafted during this engagement
5.2	Information security policy	Available

Clause	Required documented information	Status at assessment
6.1.2	Information security risk assessment process	Available
6.1.3	Information security risk treatment process	Available
6.1.3 d)	Statement of Applicability	Draft — justifications incomplete
6.2	Information security objectives	Partial — no security KPIs
7.2	Evidence of competence	Available
7.5	Documented information required by the standard and by the organisation	Available
8.1	Evidence that processes are carried out as planned	Available
8.2 / 8.3	Risk assessment results and risk treatment results	Available
9.1	Evidence of monitoring and measurement results	Partial — not linked to ISMS objectives
9.2	Internal audit programme and audit results	Programme defined, first cycle pending
9.3	Results of management reviews	Not available
10.2	Nonconformities and corrective actions taken	Partial — tickets, not a formal register

6.3 Proposed security KPI set

Clause 6.2 requires measurable objectives and Clause 9.1 requires that they are monitored and evaluated. A ten-metric set was proposed to close both gaps with one artefact.

Metric	Target	Frequency	Owner
Data centre infrastructure availability	≥ 99.9%	Monthly	DC Operations
Mean time to acknowledge a security alert	≤ 15 minutes	Monthly	SOC
Mean time to resolve a high-severity incident	≤ 4 hours	Monthly	IT Security
SOC alerts closed within SLA	≥ 95%	Monthly	SOC
Backup success rate	≥ 99%	Monthly	IT Operations
Restore tests passed	100% of scheduled tests	Quarterly	IT Operations
Critical vulnerabilities remediated within window	≤ 14 days, ≥ 95%	Monthly	IT Security
Privileged and physical access reviews completed	100%	Quarterly	Access Management
Corrective actions closed by due date	≥ 90%	Monthly	ISMS Manager
Security awareness training completion	≥ 95%	Annually	HR / IT Security

6.4 Internal audit and management review

Audit programme	Annual cycle covering all clauses and all applicable Annex A controls, risk-weighted so that data centre physical security, access management and backup are audited twice a year. Auditors must be independent of the area audited.
Audit outputs	Audit plan, checklists, findings classified as major, minor or observation, and corrective action requests fed into the central log.
Management review inputs	Status of prior actions, changes in internal and external issues and interested-party requirements, ISMS performance against the KPI set, audit results, nonconformity and corrective action status, risk assessment and treatment status, and improvement opportunities.
Management review outputs	Decisions on continual improvement, resource needs and any change to the ISMS — minuted, with named owners and due dates.
Cadence	At least annually, and after any major incident or significant infrastructure change.

7. Roadmap to Certification

Phase	Timing	Focus	Exit criteria
Phase 1 Foundation	Month 1–2	Close documentation gaps: ISMS scope statement, SoA justifications, security KPIs, resource plan, communication plan and control ownership	Every mandatory document exists and is approved
Phase 2 Operate	Month 2–4	Run the controls and generate records: monitoring checklist, corrective action log, evidence handling work instruction, secure-area evidence	At least three months of operating records available
Phase 3 Consolidate	Month 4–5	Finalise the SoA and risk register, gather supplier and facility evidence, assemble the management review pack	SoA complete for all 93 controls with rationale
Phase 4 Verify	Month 5–6	Full internal audit cycle, corrective action closure, first management review	Zero open major findings; management review minuted
Certification audit	Month 7+	Stage 1 documentation review, then Stage 2 implementation audit by the certification body	Certificate issued, valid three years

7.1 What the certification body will look for

- **Stage 1** — a documentation and readiness review. The auditor tests the scope statement, the SoA, the risk methodology and whether the internal audit and management review have been planned. This is where an unjustified exclusion stops the project.
- **Stage 2** — an implementation audit. The auditor samples records to confirm controls actually operate: access logs, visitor records, backup and restore results, incident tickets, change records, KPI reports.
- **Evidence period** — a certification body normally expects the ISMS to have been operating long enough to produce meaningful records, including one completed internal audit and one management review.
- **After certification** — surveillance audits in years one and two and a full recertification audit in year three.

8. Outcomes, Skills and Lessons Learned

8.1 Outcomes delivered

- An objective, evidence-based readiness baseline across 115 assessed items where none previously existed.
- Fifteen gaps identified, scored as eight risk scenarios and converted into ten owned corrective actions with defined evidence.
- A drafted ISMS scope statement, risk methodology, Statement of Applicability structure, KPI set and audit programme — the documents that were missing rather than the controls.
- A six-month, four-phase roadmap that sequences remediation so that Stage 1 is entered with no known documentation nonconformities.

8.2 Skills demonstrated

Standards & frameworks	ISO/IEC 27001:2022 Clauses 4–10, ISO/IEC 27002:2022 control guidance, NIST Cybersecurity Framework 2.0 as a cross-reference
GRC practice	Scope definition, gap analysis, Statement of Applicability drafting, risk assessment and treatment, corrective action management, internal audit planning
Assessment technique	Documentation review, structured control questionnaires, stakeholder interviewing, physical site survey, evidence sampling
Technical domains	Data centre physical and environmental security, network segregation and connection control, privileged access management, backup and restore, incident response, logging and SOC operations

Communication	Executive dashboard reporting, risk articulated in business terms, prioritised remediation planning for a non-technical audience
---------------	--

8.3 Lessons learned

- **Operational maturity is not management-system maturity.** The client ran its infrastructure well — 77% of controls were fully implemented — yet every material gap sat in measurement, review and improvement. Certification failures are usually governance failures, not technical ones.
- **Scope discipline saves remediation cost.** Four of the five not-implemented items were scope questions. Recording a defensible rationale in the SoA cost hours; implementing those controls unnecessarily would have cost months.
- **A rating is only as good as the evidence behind it.** Interviews surfaced practices — such as information labelling and transfer — that no document supported. If a control cannot be evidenced, an auditor will treat it as absent.
- **Quantifying risk changes the conversation.** Converting a flat gap list into scored scenarios with residual positions gave management a defensible basis for sequencing work and allocating budget.

References

International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements.

International Organization for Standardization. (2022). ISO/IEC 27002:2022 — Information security, cybersecurity and privacy protection — Information security controls.

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0.

Engagement working papers: readiness assessment master plan, control questionnaire dataset, executive dashboard and draft Statement of Applicability (client-confidential, not reproduced).